

Purple Team Outline

Week 09: API Security Fundamentals & Enumeration

Objective: To learn how to secure the backbone of modern applications-Application Programming Interfaces (APIs).

Task : API Security, IDOR, BOLA

- **Description:** Analyze how APIs function and map out the available attack surface & Test for Insecure Direct Object Reference (IDOR) flaws in API endpoints.
- **Technical Requirements:**
 - Differentiate between REST and SOAP architectures at a high level.
 - Perform API endpoint enumeration to find "hidden" or undocumented routes
 - Manipulate request parameters to access data belonging to other users.
 - Propose defensive fixes using UUIDs and proper server-side
 - authorization checks.

Day 1

Theory tasks:

- Define API in your own words
- Define REST and SOAP in your own words
- Explain how client ↔ server communication works (simple flow) using draw.io
- Create a simple diagram showing how an API request goes from client → server → response

Practical (using Burp Suite):

- Intercept traffic from a website
- Identify at least one API request

Deliverables:

- Screenshot of intercepted request
- Screenshot of response
- Hand-drawn or digital API flow diagram
- Written definitions (API, REST, SOAP)

Day 2

Theory tasks:

- Define JSON and XML in your own words
- List 3 differences between JSON and XML
- Explain why REST prefers JSON and SOAP prefers XML
- Draw structure of JSON vs XML (visual comparison) by using draw.io

Practical (using Burp Suite):

- Capture a JSON response in Burp
- Send a sample XML request via Repeater (SOAP example)

Deliverables:

- Screenshot of JSON response
- Screenshot of XML request/response
- One self-written JSON example
- One self-written XML example
- Comparison notes (JSON vs XML)

Day 3

Theory tasks:

- Define headers, parameters, and request body
- Explain authentication vs authorization
- List common headers (Content-Type, Authorization, etc.)

Practical (using Burp Suite):

- Intercept a request in Burp
- Send to Repeater
- Modify headers, parameters, and body

Deliverables:

- Screenshot of original request
- Screenshot of modified request
- Screenshot showing response change
- Short explanation of what change affected the response

Day 4

Theory tasks:

- Define Broken Access Control (BAC)
- Define IDOR in your own words
- Explain why IDOR happens

Practical (using Burp Suite):

- Use PortSwigger Web Security Academy IDOR labs/ DVWA / Owasp Juice Shop
- Intercept and modify object ID

Deliverables:

- Screenshot of original request
- Screenshot after ID change
- Screenshot of unauthorized data
- Written explanation of IDOR

Day 5

Theory tasks:

- Define BOLA in your own words
- Explain how BOLA is different from IDOR
- Explain why BOLA is common in APIs
- Create a comparison table: IDOR vs BOLA

Practical (using Burp Suite):

- Intercept API requests in Burp
- Modify object IDs in endpoints
- Observe authorization behavior

Deliverables:

- Screenshot of intercepted API request
- Screenshot of modified request
- Screenshot of response difference
- Written IDOR vs BOLA comparison
- Short explanation of vulnerability

Day 6

Theory tasks:

- Write or describe how to fix it using:
 -  Object-level authorization check
 -  Session-based user validation
 -  Backend ownership verification
- Rewrite the endpoint design securely (example expected):
 - Instead of `/users/{id}`, what safer approach can be used?

Scenario:

GET /api/account/5001/balance

- Identify BOLA risk in financial data access
- What data leak can happen if ID is modified?
- Explain attack flow step-by-step (conceptual only)
- Fix using:
 -  Authorization middleware
 -  User-to-account mapping validation
- Suggest secure endpoint alternative